

# Footprinting — Ghi chép cuối mô-đun

**Mô-đun:** Footprinting (thu thập dấu vết)

**Độ khó:** Trung bình

**Tier:** 2

**Thời gian dự kiến:** 2 ngày

**Số phần:** 21

**Bài tập tương tác:** 11

**Bài đánh giá:** 0

**Cubes:** 20

## Tổng quan mô-đun

Mô-đun dạy footprinting với dịch vụ phổ biến trong doanh nghiệp, hạ tầng. Mục tiêu **thu tối đa thông tin hữu ích trước mọi hoạt động can thiệp**, qua quan sát, liệt kê có kiểm soát và liên hệ mạnh mỗi kỹ thuật, tổ chức.

Nội dung kết hợp khái niệm — phương pháp, tầng liệt kê, dịch vụ, giao thức — và thực hành lab. Trọng tâm biến trình sát thành hiểu biết thực về mục tiêu: dịch vụ tồn tại, thông tin tiết lộ, cấu hình, quan hệ giữa thông tin.

## Chủ đề chính

- nguyên tắc liệt kê
- phương pháp liệt kê
- tên miền, tài nguyên đám mây, nhân sự
- FTP, SMB, NFS, DNS, SMTP, IMAP/POP3, SNMP
- MySQL, MSSQL, Oracle TNS
- IPMI
- giao thức quản trị từ xa Linux, Windows
- lab footprinting ba mức độ

## Kiến thức tiên quyết gợi ý

- Linux Fundamentals — Nền tảng Linux
- Network Enumeration with Nmap — Liệt kê mạng bằng Nmap
- Introduction to Networking — Nhập môn mạng
- Windows Fundamentals — Nền tảng Windows

## Cấu trúc

1. Nguyên tắc liệt kê
2. Phương pháp liệt kê
3. Thông tin tên miền
4. Tài nguyên đám mây

5. Nhân sự
6. FTP
7. SMB
8. NFS
9. DNS
10. SMTP
11. IMAP / POP3
12. SNMP
13. MySQL
14. MSSQL
15. Oracle TNS
16. IPMI
17. Giao thức quản trị từ xa Linux
18. Giao thức quản trị từ xa Windows
19. Lab Footprinting — Dễ
20. Lab Footprinting — Trung bình
21. Lab Footprinting — Khó

## Cách tổ chức bản ghi chép

Lý thuyết theo thứ tự mô-đun. Bài thực hành tương ứng đặt **ngay sau lý thuyết cùng phần**, giữ luồng **lý thuyết trước, thực hành sau**.

Nội dung thực hành tích hợp từ phần trích đã xác minh, giữ câu hỏi, đáp án, log cùng nhau trong từng phần. Bản dịch thêm câu hỏi tiếng Việt; lệnh, đầu ra và bằng chứng gốc giữ nguyên.

## Phần 01 — Nguyên tắc liệt kê

### Tóm tắt lý thuyết

Liệt kê là thu và liên hệ thông tin hữu ích về mục tiêu từ nhiều nguồn. Phân biệt **OSINT thuần thụ động**, chỉ dùng dữ liệu đã công khai, với **liệt kê chủ động**, tương tác trực tiếp, lặp lại với dịch vụ, tên miền, máy, giao thức.

Mục tiêu không phải “vào hệ thống thật nhanh” mà **tìm mọi đường khả dĩ tới nó**. Xem điều thấy, không thấy, manh mối gợi ý. Không ép một đường duy nhất mà xây hình dung, bối cảnh, khả năng.

Tư duy điều tra: thấy gì? Suy ra gì? Thiếu gì? Điều không thấy nói gì? Liệt kê tốt phụ thuộc cả thu thập và đọc kết quả có phản biện.

### Điểm chính

- Phân biệt OSINT thụ động, liệt kê chủ động.
- Luôn tìm nhiều đường tới mục tiêu.
- Xem thiếu thông tin là dữ liệu liên quan.
- Hiểu mục tiêu trước nghĩ khai thác.

## Phần 02 — Phương pháp liệt kê

### Tóm tắt lý thuyết

Phương pháp theo tầng tổ chức liệt kê, tránh bỏ sót. Không chuỗi lệnh cứng mà **mô hình tư duy** cho nhiều môi trường. Quy trình linh hoạt vì mỗi phát hiện ảnh hưởng bước sau.

Các tầng: **hiện diện Internet (Internet Presence)**, **cổng mạng (Gateway)**, **dịch vụ tiếp cận được (Accessible Services)**, **tiến trình (Processes)**, **đặc quyền (Privileges)**, **thiết lập hệ điều hành (OS Setup)**. Bắt đầu hiện diện công khai, mức lộ, ranh giới, dịch vụ; mở rộng tới tiến trình nội bộ, quyền, cấu hình OS.

Không làm checklist mù quáng; phương pháp cấu trúc suy luận, ghi chú, tránh quên khía cạnh quan trọng.

### Điểm chính

- Lập, không tuyến tính.
- Mỗi tầng tăng hiểu biết.
- Mô-đun chủ yếu đào sâu **dịch vụ tiếp cận được**.
- Tạo quy trình lặp lại, thích nghi được.

## Phần 03 — Thông tin tên miền

### Tóm tắt lý thuyết

Tên miền là thành phần chính hiện diện doanh nghiệp trên Internet. Trước tương tác chủ động, có thể biết nhiều từ website, chứng chỉ, DNS công khai, bản ghi liên quan, công cụ bên thứ ba.

Chứng chỉ, log minh bạch chứng chỉ có thể lộ tên miền con, tên nội bộ, mẫu đặt tên. `crt.sh`, công cụ tìm kiếm, dịch vụ tra IP/máy giúp tìm máy trực tiếp công khai, nhà cung cấp ngoài, SaaS, tài sản liên quan.

A, MX, NS, TXT, CNAME, PTR, SOA giúp hiểu hạ tầng, email, nhà cung cấp, xác minh tên miền, tích hợp quản trị; tạo bản đồ ban đầu.

### Điểm chính

- Tên miền lập bản đồ hiện diện, dịch vụ, bên thứ ba.
- Chứng chỉ, CT log lộ tên miền con, mẫu tên.
- DNS cho bối cảnh kỹ thuật, tổ chức.
- Liệt kê tốt giảm dò mù ở bước sau.

## Phần 04 — Tài nguyên đám mây

### Tóm tắt lý thuyết

Đám mây thuộc hạ tầng thường ngày, hay để dấu vết footprinting: lưu trữ công khai/cấu hình sai, tài liệu lập chỉ mục, đối tượng tĩnh được trang web tham chiếu, bucket gắn tên tổ chức.

Ngoài tìm kiếm, phân tích **mã nguồn**, tham chiếu trang, metadata dẫn tới bucket, blob, PDF, ảnh, script, đối tượng ngoài. Dịch vụ bên thứ ba lập danh mục tài nguyên công khai giúp tìm nội dung theo tên doanh nghiệp.

Sai sót con người trên cloud có thể lộ tệp nhạy cảm, thông tin xác thực, khóa, dữ liệu tự động hóa. Cloud là phần thiết yếu bề mặt trình sát.

### Điểm chính

- Bucket, blob, đối tượng lộ cho dữ liệu giá trị.
- Mã, HTML giúp định vị cloud.
- Tìm kiếm, chỉ mục tăng khám phá thụ động.
- Cloud cấu hình sai thường lộ bí mật.

## Phần 05 — Nhân sự

### Tóm tắt lý thuyết

Nhận diện người liên quan tổ chức có giá trị. Hồ sơ công khai, tuyển dụng, mô tả nghề, bài kỹ thuật, kho mã lộ công nghệ, đội nội bộ, ngôn ngữ, framework, cơ sở dữ liệu, nhà cung cấp, trách nhiệm.

Nhân viên hay lộ hơn ý định qua diễn đàn, GitHub, LinkedIn, trang cá nhân: tên người dùng, cấu trúc dự án, cách đặt tên, hệ thống, thư viện nội bộ, cả bí mật vô tình đăng.

Dùng yếu tố con người làm nguồn bối cảnh kỹ thuật. Biết ai làm gì giúp suy stack, bề mặt, mẫu tài khoản, truy cập.

### Điểm chính

- Con người lộ công nghệ, tổ chức.
- Tuyển dụng, hồ sơ cho stack, ưu tiên kỹ thuật.
- Kho mã, bài đăng có thể có dữ liệu nhạy cảm.
- Tên, vai trò nhân viên làm phong phú liệt kê.

## Phần 06 — FTP

### Tóm tắt lý thuyết

Giao thức truyền tệp kinh điển. Phân biệt **kênh điều khiển**, **kênh dữ liệu**, chế độ **chủ động**, **thụ động**, cổng **21/TCP**, **20/TCP**. TFTP là biến thể đơn giản, kém an toàn hơn nhiều.

**vsFTPd** minh họa cấu hình: cho đăng nhập ẩn danh, tải lên, tạo thư mục, người ẩn danh ghi máy chủ. Những tham số thay đổi hoàn toàn giá trị dịch vụ khi footprinting.

Liệt kê lộ phiên bản, banner, cây thư mục, quyền quan sát, tệp thú vị. Nmap có script FTP; TLS/SSL có thể kiểm bằng OpenSSL khi áp dụng.

### Điểm chính

- Tách điều khiển, dữ liệu; chủ động/thụ động.
- Đăng nhập ẩn danh, ghi rất nhạy cảm.
- Thư mục liệt kê thường cho manh mối.
- Nmap xác minh mức lộ, banner, quyền quan sát.

[Nhật ký thực hành lab đã được lược bỏ khỏi bản công khai.]

## Phần 07 — SMB

### Tóm tắt lý thuyết

Giao thức chia sẻ tệp, tài nguyên phổ biến Windows và Linux qua **Samba**. Ôn SMB/CIFS, liên hệ NetBIOS, **139/TCP**, **445/TCP**, khác biệt phiên bản cũ với triển khai mới.

Quản trị: định nghĩa, đặt tên, cấu hình thư mục chia sẻ. Hiển thị, đọc/ghi, guest, mật nạ tạo tệp, quyền đặc biệt thay đổi mức lộ, có thể rò dữ liệu/quyền quá rộng.

smbclient, rpcclient, smbmap, crackmapexec, enum4linux-ng liệt kê chia sẻ, người dùng, nhóm, miền, chú thích, quyền. Liên hệ tên, chú thích, cấu trúc nội bộ thường hữu ích.

### Điểm chính

- SMB/Samba trung tâm chia sẻ mạng trong.
- Tên, chú thích cho bối cảnh quý.
- Guest access, browseable, writable rất quan trọng.
- Liệt kê có thể lộ nhiều không cần khai thác mạnh.

[Nhật ký thực hành lab đã được lược bỏ khỏi bản công khai.]

## Phần 08 — NFS

### Tóm tắt lý thuyết

Chia sẻ tệp điển hình [LAB\_CREDENTIAL\_REDACTED] Quan hệ [LAB\_CREDENTIAL\_REDACTED], NFS, cổng 111/TCP/UDP, 2049/TCP/UDP\*; khác biệt phiên bản, vai trò exports.

Cấu hình định thư mục xuất cho [LAB\_CREDENTIAL\_REDACTED] nào. rw, insecure, no\_root\_squash, no\_subtree\_check, sync đổi rủi ro, mức lộ. no\_root\_squash đặc biệt nhạy vì đổi quan hệ root từ xa với quyền cục bộ.

Footprinting thường tìm exports, mount chia sẻ, liệt kê, xem chủ tệp, UID/GID, suy người dùng, quyền hệ thống từ xa.

### Điểm chính

- Lộ toàn thư mục hệ thống tệp.
- exports là trung tâm cấu hình.
- no\_root\_squash rất nhạy.
- Mount có thể lộ người dùng, nhóm, dữ liệu đối chiếu.

[Nhật ký thực hành lab đã được lược bỏ khỏi bản công khai.]

## Phần 09 — DNS

### Tóm tắt lý thuyết

Nền tảng mạng nổi tên với địa chỉ, dịch vụ, metadata. Ôn loại máy chủ, bản ghi, logic phân giải. Không chỉ tên công khai: có thể lộ chi tiết nội bộ, email, ủy quyền, toàn cấu trúc zone.

**BIND** minh họa cấu hình, tệp zone, tra ngược. allow-query, allow-recursion, allow-transfer, thống kê zone có thể làm dịch vụ lộ hơn cần thiết.

dig, dò tên miền con, **AXFR** khi chuyển zone cho phép sai tạo liệt kê phong phú. Zone đúng lộ máy trong, TXT, domain controller, quy ước tên...

### Điểm chính

- DNS lộ cấu trúc, dịch vụ, mail, tổ chức.
- Chuyển zone sai là rò rỉ giá trị cao.
- BIND, tệp zone giúp hiểu logic.
- Tên miền con, TXT, tra ngược làm giàu trinh sát.

[Nhật ký thực hành lab đã được lược bỏ khỏi bản công khai.]

## Phần 10 — SMTP

### Tóm tắt lý thuyết

Giao thức chính gửi mail. Luồng client, submission agent, relay, delivery agent; **25/TCP**, **465/TCP**, **587/TCP**. Lệnh HELO, EHLO, VRFY, MAIL FROM, RCPT TO, DATA, QUIT.

**Postfix** minh họa mặc định, kiểm soát. Relay quá thoáng hoặc lộ quá mức lệnh, phản hồi liệt kê có thể gây vấn đề nghiêm trọng.

SMTP không chỉ banner: có thể cho mẫu tên, miền trong, người dùng hợp lệ, hành vi với ít dấu vết. Cần cẩn trọng, đặc biệt sản xuất.

### Điểm chính

- Có thể lộ tên, miền, người dùng.
- VRFY, hành vi giúp xác minh tài khoản.
- Open relay là cấu hình bảo mật nghiêm trọng.
- Liệt kê email cẩn thận cho manh mối bước khác.

[Nhật ký thực hành lab đã được lược bỏ khỏi bản công khai.]

## Phần 11 — IMAP / POP3

### Tóm tắt lý thuyết

Truy cập mail đã chuyển tới. **POP3** đơn giản, thiên tải thư; **IMAP** phong phú, thư mục, đồng bộ. Cổng **110/995** POP3, **143/993** IMAP.

**Dovecot** minh họa mặc định, tùy chọn quản trị. Lệnh hữu ích; chứng chỉ, banner, tên tổ chức, cấu trúc hộp thư có thể xuất hiện ngay liệt kê.

Có thể lộ tổ chức, FQDN, phiên bản tùy chỉnh, địa chỉ quản trị, nội dung thư mục/hộp truy cập được. Thông tin xác thực hợp lệ tăng giá trị liên hệ.

### Điểm chính

- Lộ định danh tổ chức, bối cảnh quản trị.
- Chứng chỉ, banner xác nhận FQDN, tổ chức.
- Thư mục mail thường có dữ liệu nhạy cảm, lịch sử.
- IMAP thường phong phú hơn POP3.

[Nhật ký thực hành lab đã được lược bỏ khỏi bản công khai.]

## Phần 12 — SNMP

### Tóm tắt lý thuyết

Giám sát, quản lý thiết bị mạng, máy chủ, dịch vụ. Khác biệt **v1**, **v2c**, **v3**: phiên bản cũ dùng **community string**, bảo vệ không bằng v3.

**MIB**, **OID** thiết yếu để hiểu tổ chức/truy vấn dữ liệu. Cấu hình sai có thể lộ mô tả hệ thống, vị trí, liên hệ, gói cài, script chạy, chi tiết quý khác.

snmpwalk, onesixtyone, braa cho thấy community string đúng có thể mở góc nhìn rộng đáng ngạc nhiên.

### Điểm chính

- Lộ hơn phiên bản, hostname nhiều.
- Community string yếu biến thành nguồn dữ liệu giàu.
- MIB, OID hỗ trợ diễn giải đúng.
- v2c vẫn phổ biến, cần chú ý mạng trong.

[Nhật ký thực hành lab đã được lược bỏ khỏi bản công khai.]

## Phần 13 — MySQL

### Tóm tắt lý thuyết

Hệ quản trị cơ sở dữ liệu quan hệ phổ biến [LAB\_CREDENTIAL\_REDACTED] Ôn client-server, **SQL** truy vấn/sửa, phổ biến trong **LAMP**, **LEMP**.

Chú ý cơ sở dữ liệu nội bộ, metadata mysql, information\_schema, performance\_schema, sys; tùy chọn người dùng, mật khẩu, debug, nhập/xuất đổi mức lộ.

Cổng **3306/TCP**. Ban đầu nhận diện phiên bản, xác minh truy cập bằng thông tin xác thực, liệt kê cơ sở dữ liệu, hiểu vai trò.

#### Điểm chính

- Thường giữ “trái tim” ứng dụng.
- Liên hệ ngay 3306 với MySQL.
- Tự động cần xác minh thủ công.
- `information_schema`, `sys` giúp hiểu cấu trúc, metadata.

[Nhật ký thực hành lab đã được lược bỏ khỏi bản công khai.]

## Phần 14 — MSSQL

### Tóm tắt lý thuyết

Microsoft SQL Server phổ biến Windows doanh nghiệp, nhất là .NET, tích hợp mạnh định danh miền. Client **SSMS**, công cụ `mssqlclient.py` được đề cập.

Ôn cơ sở dữ liệu hệ thống `master`, `model`, `msdb`, `tempdb`, `resource`; xác thực Windows, tên instance, hostname, **named pipes** khi dịch vụ lộ.

Thường lắng nghe **1433/TCP**. Script Nmap cho hostname, instance, phiên bản và thông tin trình sát hữu ích.

#### Điểm chính

- Gắn mạnh Windows, AD.
- `mssqlclient.py` quan trọng cho thực hành.
- Instance, hostname, named pipes quý.
- Cơ sở dữ liệu mặc định giúp tách đặc thù môi trường.

[Nhật ký thực hành lab đã được lược bỏ khỏi bản công khai.]

## Phần 15 — Oracle TNS

### Tóm tắt lý thuyết

Tầng giao tiếp Oracle để phân giải tên, nối client, chuyển kết nối, tổ chức truy cập instance/dịch vụ. **1521/TCP**, **listener**, **SID**, **service name** là trọng tâm.

**\*\*tnsnames.ora định logic phía client; listener.ora định hành vi phía server. ODAT\*\*** là công cụ liệt kê Oracle.

Thực tế tìm listener, SID, thông tin xác thực hợp lệ, bối cảnh instance. Sau xác thực có thể liệt kê bảng, quyền, dữ liệu quản trị rất nhạy.

#### Điểm chính

- Listener 1521 là chỉ báo chính.
- SID, service name bắt buộc hiểu.
- Hai tệp .ora giúp hiểu kiến trúc.
- ODAT, SQL\*Plus quan trọng.

[Nhật ký thực hành lab đã được lược bỏ khỏi bản công khai.]

## Phần 16 — IPMI

### Tóm tắt lý thuyết

Chuẩn quản trị ngoài băng, quản lý phần cứng độc lập OS chính. Thường qua **iLO**, **iDRAC**, **BMC**, **UDP 623**.

BMC hoạt động dưới OS nên lộ sai có tác động cao: giám sát, console từ xa, khởi động lại, đổi boot, chức năng quản trị nhảy.

BMC công khai, mật khẩu mặc định, phân đoạn kém khiến IPMI nguy hiểm trong mạng trong. Liệt kê nhận diện phiên bản, xác thực, rủi ro vận hành.

#### Điểm chính

- Ngoài băng, độc lập OS.
- UDP 623 liên quan giao thức.
- BMC lộ là phát hiện tác động cao.
- Mặc định, cách ly yếu tăng rủi ro.

[Nhật ký thực hành lab đã được lược bỏ khỏi bản công khai.]

## Phần 17 — Giao thức quản trị từ xa Linux

### Tóm tắt lý thuyết

Cơ chế quản trị chính, đặc biệt **SSH**, xác thực mật khẩu/ khóa công khai, `sshd_config`, tùy chọn nguy hiểm: root login, mật khẩu rỗng, forwarding, tunneling.

**rsync** đồng bộ/chia sẻ hiệu quả ở **873/TCP**; **r-services** cũ (`rlogin`, `rsh`, `rcp`, `rwho`, `rusers`) ở **512/513/514**. Tin cậy sai trong `hosts.equiv`, `.rhosts` gây rủi ro cao.

Không chỉ “truy cập”: bề mặt giao diện danh, tin cậy, tự động hóa, di chuyển ngang.

#### Điểm chính

- SSH chuẩn hiện đại.
- Khóa SSH lộ nghiêm trọng.
- Rsync lộ toàn tệp/thư mục.
- `hosts.equiv`, `.rhosts` chỉ báo mạnh tin cậy cấp sai.

## Phần 18 — Giao thức quản trị từ xa Windows

### Tóm tắt lý thuyết

Ba kênh **RDP**, **WinRM**, **WMI**. RDP đồ họa, **3389/TCP**; chú ý **NLA**, TLS, chứng chỉ.

**WinRM** nền PowerShell Remoting, tự động hóa, **5985/TCP** HTTP, **5986/TCP** HTTPS. **WMI** truy vấn/quản trị rộng đối tượng hệ thống, thường bắt đầu **135/TCP**.

Lộ vai trò máy, cách đặt tên, miền, cách quản trị; thiết yếu footprinting nội bộ.

#### Điểm chính

- Ba kênh chính Windows.
- Ghi NLA, chi tiết bắt tay RDP.
- WinRM chỉ báo mạnh quản trị PowerShell.
- WMI quan sát rộng tiến trình, dịch vụ, cấu hình.

[Các bài lab cuối mô-đun đã được lược bỏ khỏi bản công khai.]